

AMW Performance Evaluation System — Assessment v1.2.1

Date: 2026-06-16
Release: v1.2.1
Assessor: Noppavit (HR07) - Trainee

1. Frontend

Area	Status	Notes
React / TypeScript	✔ Pass	No TS errors (<code>tsc --noEmit</code> clean)
i18n (EN / TH / FR)	✔ Pass	All 3 locales complete; <code>cp.*</code> , <code>cal.*</code> , <code>ak.selectDate</code> , <code>rp.filterCycle/allCycles/loadFailed</code> added
ChangePasswordPage	✔ Fixed	Labels & placeholders now use <code>t('cp.*')</code> — no hardcoded EN
ForgotPasswordPage	✔ Fixed	Reset-password form labels now use <code>t('cp.*')</code>
AcknowledgementSection	✔ Fixed	<code>placeholder</code> replaced with <code>t('ak.selectDate')</code>
CalibrationPage	✔ Fixed	<code>isError</code> branch added; renders <code>EmptyState</code> on API failure
ReportsPage	✔ Fixed	<code>isError</code> branch added; cycle filter dropdown added; <code>visibleData</code> slice applied
KBT design system	✔ Pass	<code>kbt-badge-*</code> , <code>kbt-metric</code> , <code>kbt-table</code> , <code>kbt-card</code> in use throughout
Responsive layout	✔ Pass	Tablet viewport (768 px) covered by QA suite
Command palette (Ctrl+K)	✔ Pass	Filter + Enter navigation tested by QA
Accessibility	⚠ Partial	<code>aria-label</code> on bell button; no formal WCAG audit run yet

2. API & Backend Logic

Area	Status	Notes
REST API (Express + Prisma)	✓ Pass	All core routes tested: <code>/health</code> , <code>/auth/login</code> , <code>/evaluations</code> , <code>/users</code> , <code>/templates</code> , <code>/cycles</code> , <code>/reports/summary</code>
Input validation	✓ Pass	Zod schemas on auth routes; missing body → 400 confirmed by QA <code>api</code> suite
Error format	✓ Pass	All error bodies include <code>message</code> field
Forgot password flow	✓ Pass	<code>/auth/forgot-password</code> and <code>/auth/reset-password</code> routes exist; QA test confirms no crash
Save Draft endpoint	✓ Pass	Developer role can call <code>PATCH /evaluations/:id</code> without 4xx
Calibration grade endpoint	✓ Pass	<code>PATCH /evaluations/:id/summary</code> (performanceGrade) + <code>/review</code> (lock)
Audit events	✓ Pass	<code>/reports/audit-events</code> returns <code>http_mutation</code> , <code>auth_login_failed</code> , <code>export</code> events

3. Database & Storage

Area	Status	Notes
ORM	✓	Prisma 5 (stable) — PR #5 for v7 is held pending migration review
Schema migrations	✓	All migrations applied; no pending drift
Seed data	✓	Seeded admin, manager, employee, developer accounts for QA
Data integrity	✓	Foreign keys enforced; <code>totalScore</code> nullable (only set after scoring)
Prisma 5→7 upgrade	⚠ On hold	Major version jump; requires separate breaking-change review before merge

4. Auth & Permissions

Area	Status	Notes
JWT authentication	✓ Pass	Token required for all protected routes; 401 on missing/invalid token
Role model	✓ Pass	ADMIN, MANAGER, EMPLOYEE, DEVELOPER roles implemented
RBAC (frontend)	✓ Pass	<code>isAdmin = role === 'ADMIN' role === 'DEVELOPER'</code> ; route guards tested in <code>rbac</code> suite
Admin read-only eval	✓ Pass	<code>isReadOnly = user?.role === 'ADMIN'</code> on <code>EvaluationFormPage</code>
<code>/users</code> admin-only	✓ Pass	Employee and Manager roles get "Admins only" message
<code>/data</code> admin-only	✓ Pass	Employee and Manager get forbidden view
Unauthenticated redirect	✓ Pass	<code>/evaluations</code> and <code>/users</code> redirect to <code>/login</code> without session
Session clear on logout	✓ Pass	<code>localStorage</code> <code>amw-auth</code> cleared; subsequent protected route blocked
Force password change	✓ Pass	<code>ChangePasswordPage</code> shown when <code>mustChangePassword</code> flag set

5. Hosting & Deployment

Area	Status	Notes
Dev server	✓	Vite (frontend :5173) + Express (backend :3001) via <code>npm run dev</code>
Production build	✓	<code>npm run build</code> — Vite bundles to <code>frontend/dist</code>
Environment variables	✓	<code>.env</code> for DB URL, JWT secret, port — not committed to repo
Static serving	✓	Backend serves <code>frontend/dist</code> in production mode
Docker readiness	⚠	No Dockerfile present; manual server setup required
Process manager	⚠	No PM2 / systemd config — single-process, no restart on crash

6. Cloud & Compute

Area	Status	Notes
Deployment target	i	On-premises or IaaS VM (no cloud-specific config present)
CDN	⚠	Not configured; static assets served from Express
Object storage	✓	File imports streamed in-memory; no large binary blobs stored
Scalability	⚠	Single Node.js process; no horizontal scaling config

7. CI/CD & Version Control

Area	Status	Notes
Git branching	✓	<code>main</code> branch; Dependabot PRs via automated workflow
npm dependency updates	✓	PRs #6 (concurrently), #7 (@hookform/resolvers), #8 (zod) merged in v1.2.0
GitHub Actions PRs	⚠	PRs #2, #3, #9, #10 (workflow scope) — require manual web-UI merge
Automated tests	✓	QA Robot: 13 suites, 130+ tests covering auth, dashboard, evaluations, reports, calibration, RBAC, API, tablet
Release tagging	✓	Git tag + GitHub release via <code>gh release create</code>
Smoke mode	✓	<code>QA_SMOKE=1 npm run qa</code> runs auth/dashboard/navigation subset only

8. Security & RLS

Area	Status	Notes
SQL injection	✓	Prisma parameterised queries throughout
XSS	✓	React escapes output by default; no <code>dangerouslySetInnerHTML</code>
CSRF	⚠	JWT in localStorage (no SameSite cookie); acceptable for SPA but not cookie-based
Password hashing	✓	bcrypt (assumed from auth implementation)
Audit log	✓	HTTP mutation, failed login, export events recorded
Row-level security	⚠	RLS enforced at application layer (role checks in API); no DB-level RLS
Threat model	✓	<code>docs/threat-model.md</code> present and up to date

9. Rate Limiting

Area	Status	Notes
Auth endpoint	✓	Rate limiter on <code>/auth/login</code> — QA tests detect 429 and skip gracefully
General API	⚠	No per-IP rate limiter on non-auth routes
Recommendation	—	Add <code>express-rate-limit</code> globally with a 200 req/min baseline

10. Caching & CDN

Area	Status	Notes
TanStack Query cache	✓	Client-side stale-while-revalidate; <code>queryKey</code> designed for targeted invalidation
HTTP cache headers	⚠	No <code>Cache-Control</code> headers set on API responses
CDN	⚠	Not configured — all assets via Express; recommend Nginx or Cloudflare in front
Static asset hashing	✓	Vite appends content hash to bundle filenames

11. Load Balancing & Scaling

Area	Status	Notes
Current state	⚠	Single process, no load balancer
DB connection pool	✓	Prisma manages pool automatically
Stateless API	✓	JWT auth is stateless — horizontal scaling is feasible
Recommendation	—	Reverse proxy (Nginx) + PM2 cluster mode for multi-core utilisation

12. Error Tracking & Logs

Area	Status	Notes
Server-side logging	⚠	<code>console.log</code> only; no structured logging library
Client-side errors	⚠	No Sentry / error boundary reporting configured
Error boundaries	⚠	React error boundaries not implemented; unhandled errors show blank page
API error format	✓	Consistent <code>{ message }</code> shape on all 4xx/5xx responses
Audit trail	✓	Mutation and auth events stored in DB, visible in Reports page
Recommendation	—	Add <code>winston</code> (server) + Sentry (client) for production observability

13. Availability & Recovery

Area	Status	Notes
Health endpoint	✓	<code>GET /health</code> returns <code>{ status: 'ok' }</code> — usable for uptime monitors
Process restart	⚠	No auto-restart on crash (no PM2 / systemd)
Database backup	⚠	No automated backup policy documented
Graceful shutdown	⚠	No <code>SIGTERM</code> handler; in-flight requests may drop on restart
Recommendation	—	PM2 with <code>--watch false</code> , Postgres WAL or daily <code>pg_dump</code> to object storage

Summary

Category	Status
Frontend	✔ Good — all i18n fixed, error states added, cycle filter live
API & Backend Logic	✔ Good
Database & Storage	✔ Good (Prisma 7 upgrade on hold)
Auth & Permissions	✔ Good
Hosting & Deployment	⚠ Manual — no Docker / process manager
Cloud & Compute	⚠ No CDN or scaling config
CI/CD & Version Control	✔ Good — QA Robot at 130+ tests
Security & RLS	✔ Good — app-layer RLS, no DB-level
Rate Limiting	⚠ Auth only; general routes unprotected
Caching & CDN	⚠ Client cache only
Load Balancing & Scaling	⚠ Single process
Error Tracking & Logs	⚠ Console only — no structured logging or Sentry
Availability & Recovery	⚠ No auto-restart or backup policy

Production readiness score: 7 / 13 categories fully addressed.

Remaining gaps are infrastructure/ops concerns, not blockers for internal deployment.